

PRACTICAL LABORATORY ASSIGNMENT

Full Name	OSAWARU PRAISE
Registration Number	C11/26/CGRCE/17564
Email Address	c11.cgrce2617564@icdfa.edu.ng
Cohort / Batch	26
Date Submitted	11 th September 2026

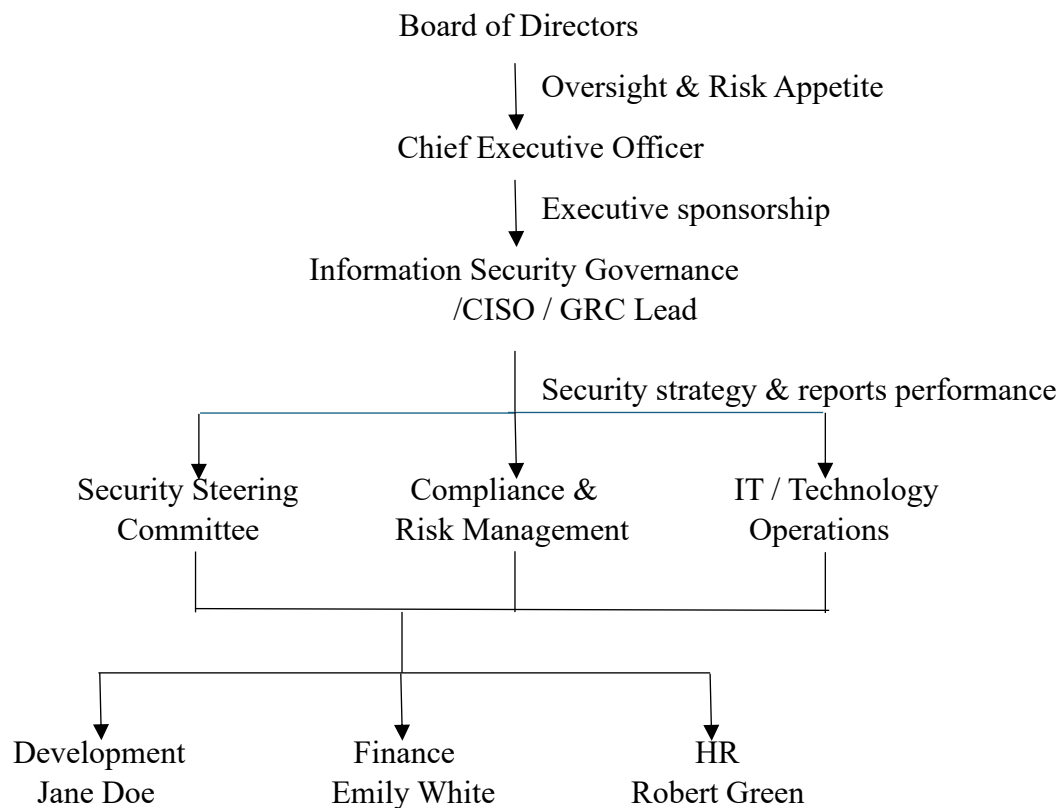
5. Governance Blueprint

Required Evidence Task 1

1. A current-state governance gap assessment identifying the most important weaknesses in GHC's ad-hoc model.

Governance Area	Current Gap	Governance Impact
Leadership & Oversight	Security activities appear to be handled mainly within IT, with no clearly defined Board-level security oversight.	Security decisions may not receive sufficient executive attention or direction.
Roles & Responsibilities	John Smith, the IT Manager, performs infrastructure and some security activities, but formal security ownership is unclear.	It may be difficult to determine who is accountable when a security issue occurs.
Risk Management	The organisation has experienced a data-leakage near-miss, suggesting that security is being addressed reactively rather than through a structured risk-management process.	Important risks may not be identified and treated before they become incidents.
Policy Framework	GHC has grown through acquisitions, making inconsistent approaches likely.	Different teams or acquired organisations may follow different security expectations.
Business Alignment	Security responsibilities are not clearly connected to GHC's business goals such as growth, customer trust, innovation and regulatory compliance.	Security investments may focus too heavily on technical issues rather than business priorities.
Performance Measurement	There is no evidence in the scenario of a formal governance reporting structure or consistent Board-level security metrics.	Leadership may have difficulty understanding GHC's security posture and making informed decisions.
Assurance	There is no clearly identified independent assurance function in the current structure.	Management may not receive sufficient independent confirmation that security controls are effective.

2. A proposed security governance organizational chart showing the Board, CEO, governance function and relevant business/technology relationships.



3. A RACI matrix covering at least six governance activities, including policy approval, risk review and incident response planning.

Governance Activity	Board	CEO	Security Governance / CISO	SSC	IT Manager	Compliance	Business Leaders
Security strategy approval	A	R	R	C	C	C	C
Information security policy approval	A	R	R	C	C	C	I
Enterprise security risk review	A	C	R	R	C	C	C
Security budget and resource planning	C	A	R	C	C	C	I
Incident response planning	I	A	R	C	R	C	C
Major security incident escalation	I	A	R	C	R	C	C

Regulatory compliance oversight	I	A	C	C	I	R	C
Security performance reporting	I	A	R	C	C	C	I

4. A short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management.

The proposed governance structure improves accountability by assigning clear ownership to the Board, CEO, security governance function, Security Steering Committee, IT and business units. This reduces the ambiguity present in GHC's current ad-hoc approach and ensures that security decisions have an identifiable owner. It also improves transparency because security risks, performance and major incidents can be escalated through a defined reporting structure to executive leadership and the Board.

The structure also supports business alignment and risk management. GHC's security programme can be linked directly to its objectives of expanding market share, maintaining customer trust, improving operational efficiency, supporting AI-driven innovation and achieving regulatory excellence. Rather than treating security as only an IT responsibility, the proposed model makes it an enterprise-wide governance responsibility.

6. Information Security Charter

Required Evidence Task 2

5. Completed GHC Information Security Charter.

1. Purpose

The purpose of this Information Security Charter is to establish the authority, responsibilities and governance framework for managing information security at GlobalHealth Connect (GHC).

The Charter ensures that information security supports GHC's business objectives while protecting the confidentiality, integrity and availability of information and technology resources. It provides a formal mandate for identifying and managing security risks, maintaining customer trust, supporting regulatory compliance and enabling secure business innovation.

The Charter also establishes clear accountability for information security decisions and provides a basis for consistent security governance across GHC following its rapid growth and acquisitions.

2. Scope

This Charter applies to:

- All GHC employees, contractors and relevant third parties.
- All business units and functions involved in GHC's operations.

- GHC's information, information systems, applications, technology infrastructure and cloud-based patient-management services.
- Security risks associated with the development, deployment and operation of GHC's products and services.
- Security and compliance activities relating to GHC's customers, business operations and strategic initiatives.

The Charter applies across GHC and is intended to provide a consistent governance approach while allowing appropriate consideration of specific business and operational requirements.

3. Authority

The **Board of Directors** has ultimate oversight responsibility for information security governance at GHC and establishes the organisation's overall risk appetite.

The **CEO** provides executive sponsorship and ensures that information security is aligned with GHC's strategic objectives.

The **Information Security Governance function/CISO** is authorised to develop and coordinate GHC's information security programme, establish security requirements, monitor security risks and performance, and escalate significant security matters to executive leadership and the Board.

The **Security Steering Committee (SSC)** provides cross-functional oversight and supports decisions involving significant security risks, priorities, policies and competing business requirements.

Business and technology leaders are responsible for implementing approved security requirements within their respective areas.

4. Roles and Responsibilities

Role	Key Responsibilities
Board of Directors	Provide oversight, approve security strategy where required, establish risk appetite and monitor significant information security risks.
CEO	Provide executive sponsorship, ensure strategic alignment and support appropriate allocation of resources.
CISO / Security Governance Lead	Develop the security strategy, coordinate the security programme, manage governance processes, monitor risks and report security performance to leadership.
Security Steering Committee	Provide cross-functional oversight, review significant risks, prioritise initiatives and resolve security issues involving multiple business functions.
IT Manager	Implement and operate technical security controls and support security operations and incident response activities.
Compliance Officer	Monitor applicable regulatory obligations and coordinate compliance-related security requirements.
Business Unit Leaders	Ensure security requirements are incorporated into business processes and that identified risks are appropriately managed.

All Employees and Contractors	Follow approved security policies and procedures, complete required awareness activities and report suspected security incidents.
-------------------------------	---

5. Key Principles

GHC's information security governance shall be guided by the following principles:

1. Business Alignment

Information security decisions shall support GHC's strategic objectives, including growth, operational efficiency, customer trust, innovation and regulatory excellence.

2. Risk-Based Decision-Making

Security resources and controls shall be prioritised according to the significance and potential business impact of identified risks.

3. Accountability

Security responsibilities shall be clearly assigned, with appropriate ownership for decisions, risks and security outcomes.

4. Protection of Customer Information

GHC shall prioritise the protection of patient and customer information and maintain the confidentiality, integrity and availability of information.

5. Compliance

GHC shall proactively address applicable healthcare and data-protection obligations and maintain appropriate evidence of compliance.

6. Secure Innovation

Security shall be incorporated into new technologies, products and initiatives, including AI-driven diagnostics and secure data exchange.

7. Continuous Improvement

GHC shall regularly assess its security governance, risks, controls and performance and improve them where necessary.

8. Transparency and Oversight

Significant security risks, incidents and performance information shall be communicated to appropriate management and governance bodies to support informed decision-making.

6. Reporting Structure

Information security governance shall operate through a defined reporting structure:

Board of Directors → CEO → CISO/Security Governance Function → Security Steering Committee → Business and Technology Functions

The CISO/Security Governance function shall provide regular reporting to executive leadership on:

- Significant security risks and risk treatment.

- Security incidents and emerging threats.
- Security performance and key metrics.
- Regulatory and compliance matters.
- Security initiatives and resource requirements.
- Progress against strategic security objectives.

Significant security risks or incidents that could materially affect GHC's customers, operations, reputation, regulatory position or strategic objectives shall be escalated to executive leadership and, where appropriate, the Board.

7. Review and Approval

This Information Security Charter shall be formally reviewed at least annually and whenever there are significant changes to GHC's business strategy, technology environment, regulatory obligations, organisational structure or information security risk profile.

The CISO/Security Governance function shall coordinate the review and propose necessary updates.

Material changes shall be reviewed by the Security Steering Committee and submitted to the appropriate executive authority and Board for approval.

All approved versions shall be communicated to relevant stakeholders and maintained as part of GHC's information security governance documentation.

6. A 1–2 paragraph justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

To: Marcus Thorne, CFO

From: Information Security Governance / CISO

Subject: Information Security Charter and Strategic Alignment

The proposed Information Security Charter provides GHC with a formal governance structure for managing information security as an enterprise-level business responsibility rather than treating it solely as an IT function. It directly supports GHC's 2026 strategic goals by requiring security to be considered in market expansion, operational efficiency, customer trust, innovation and regulatory compliance. For example, protecting patient information supports customer trust, while incorporating security into AI-driven diagnostics and secure data exchange enables innovation without ignoring associated security risks. The risk-based approach also helps ensure that security resources are directed towards the areas with the greatest potential business impact.

For GHC's leadership, the Charter creates clearer accountability for security decisions and establishes a defined reporting structure through the CEO, CISO/Security Governance function and Security Steering Committee. This will allow management and the Board to receive meaningful information about significant risks, incidents, performance and resource

requirements. From a financial perspective, this structure supports better investment decisions because security initiatives can be prioritised based on business risk and strategic value rather than ad-hoc technical requirements. The Charter therefore provides a foundation for balancing security investment with GHC's growth, efficiency and innovation objectives.

6. Board Reporting and Security Metrics

Required Evidence Task 3

7. A one-page Board Executive Summary containing an overall Red/Amber/Green posture assessment and justification.

Overall Security Posture:  RED — High Risk

GHC's overall security posture should be rated Red because the six-month data shows a consistent deterioration in several important security indicators. Phishing attempts increased from 150 in September to 320 in February, while malware events increased from 25 to 50. At the same time, the percentage of critical vulnerabilities patched declined from 67% to 55%. Although security training completion improved from 45% to 70%, high-risk incidents increased from 2 to 7 over the same period.

The combination of increasing threats, declining critical-vulnerability remediation and rising high-risk incidents indicates that GHC's security risk is increasing faster than its current controls are addressing it. This is particularly important given GHC's objective of maintaining customer trust and avoiding major data breaches. The Board should therefore prioritise vulnerability remediation, incident-risk reduction and strengthening employee security awareness.

8. Five selected security metrics showing current status, six-month trend and concise business commentary.

Metric	Current Status (Feb)	Six-Month Trend	Board-Level Commentary
Phishing Attempts	 320	↑ 150 → 320	Phishing activity has more than doubled, increasing the likelihood of credential compromise and successful attacks.
Malware Events	 50	↑ 25 → 50	Malware events doubled, indicating increasing malicious activity and potential pressure on GHC's technical controls.
Critical Vulnerabilities Patched	 55%	↓ 67% → 55%	Remediation performance is declining while the number of critical vulnerabilities

			is increasing, creating significant exposure.
Security Training Completion	● 70%	↑ 45% → 70%	Training participation is improving, but 30% of personnel remain untrained, leaving an important human-risk gap.
High-Risk Security Incidents	● 7	↑ 2 → 7	High-risk incidents increased significantly and represent a growing potential impact on operations, customer trust and regulatory obligations.

Six-Month Trend Analysis

Phishing

Phishing attempts increased every month:

150 → 180 → 210 → 250 → 280 → 320

This represents an increase of approximately 113% from September to February.

Business implication: Increasing phishing activity creates greater exposure to credential theft, account compromise and potential unauthorised access to GHC systems and information.

Malware

Malware events also increased consistently:

25 → 30 → 35 → 40 → 45 → 50

This represents a 100% increase.

Business implication: The increase suggests growing malicious activity and may increase the likelihood of disruption, data compromise and recovery costs.

Critical Vulnerabilities

The number of critical vulnerabilities increased:

15 → 20 → 25 → 30 → 35 → 40

However, the percentage patched declined:

67% → 60% → 60% → 60% → 57% → 55%

This is particularly concerning because GHC is simultaneously accumulating more critical vulnerabilities while its remediation rate is falling.

Training

Training completion improved:

45% → 50% → 55% → 60% → 65% → 70%

This is the only consistently positive trend among the selected indicators.

However, the current 70% completion rate still means 30% of personnel have not completed the required training.

High-Risk Incidents

High-risk incidents increased:

2 → 3 → 4 → 5 → 6 → 7

This represents a 250% increase from September to February.

Business implication: This is the strongest indicator that increasing threat activity is translating into greater organisational risk.

9. At least two priority risks/issues and two actionable recommendations.

Risk 1 — Increasing High-Risk Security Incidents

Evidence: High-risk incidents increased from 2 in September to 7 in February.

Why it matters: Increasing high-risk incidents may result in operational disruption, exposure of sensitive information, financial losses, reputational damage and regulatory consequences.

Priority: High

Recommendation

GHC should strengthen incident prevention and response by analysing the causes of recent high-risk incidents, improving detection and response processes, and ensuring that significant incidents are escalated through the established governance structure.

Risk 2 — Declining Critical Vulnerability Remediation

Evidence: Critical vulnerabilities increased from 15 to 40, while the percentage patched declined from 67% to 55%.

Why it matters: GHC is leaving a growing proportion of critical vulnerabilities unresolved, increasing the potential attack surface and likelihood of successful exploitation.

Priority: High

Recommendation

GHC should establish a risk-based vulnerability remediation programme with defined remediation targets, ownership and escalation for overdue critical vulnerabilities. Progress should be reported regularly to the Security Steering Committee and Board.

10. A short rationale explaining why your five selected metrics are suitable for Board oversight.

The selected metrics are appropriate for Board oversight because they move beyond purely technical information and provide an indication of organisational risk and control effectiveness.

The Board does not need to know every firewall alert, endpoint event or technical vulnerability. Instead, it needs information that helps answer whether GHC's security risks are increasing or decreasing, whether controls are working, and whether additional resources or strategic action are required.

The selected metrics therefore connect threat activity, technical exposure, employee readiness and actual high-risk incidents to business concerns such as customer trust, operational resilience and regulatory risk. This supports the Week 1 principle that security performance should be measured and communicated in a way that supports governance and business decision-making.

6. Board Reporting and Security Metrics

Required Evidence Task 4

10. Security Steering Committee Terms of Reference covering purpose, scope, membership, responsibilities, meeting cadence, decision authority and reporting.

1. Purpose

The Security Steering Committee (SSC) is established to provide cross-functional oversight and direction for information security at GlobalHealth Connect (GHC). The Committee will ensure that significant security decisions are aligned with GHC's business objectives, risk appetite, operational requirements and regulatory obligations.

The SSC will also provide a structured forum for resolving disagreements between business, technology and security stakeholders and ensuring that security decisions are based on risk and business impact rather than individual preferences.

2. Scope

The SSC's scope includes:

- Information security strategy and priorities.
- Significant information security risks.
- Security policies and standards.
- Security investments and resource priorities.
- Major security incidents and lessons learned.

- Regulatory and compliance-related security matters.
- Security performance and Board-level reporting.
- Security requirements for new technologies and business initiatives.
- Cross-functional security issues requiring management decisions.

The password-policy disagreement between the CTO and IT Manager is an example of an issue that falls within the Committee's scope.

3. Membership

The SSC should include representatives from key business and technology functions to ensure that security decisions are not made by IT alone.

Member/Role	Primary Contribution
CEO / Executive Sponsor	Provides executive direction and ensures strategic alignment.
CISO / Security Governance Lead	Provides security expertise and coordinates the Committee.
CTO – Elena Rodriguez	Represents technology, development, innovation and operational efficiency.
IT Manager – John Smith	Represents IT operations and technical implementation.
Compliance Officer – Mark Johnson	Represents regulatory and compliance requirements.
HR Manager – Robert Green	Provides input on employee-related controls, onboarding and offboarding.
Finance Representative – Emily White	Provides business and financial impact considerations.
Relevant Business Unit Representatives	Provide operational and business requirements when necessary.

4. Responsibilities

The SSC shall:

- Review and prioritise significant information security risks.
- Review and recommend information security policies and standards.
- Ensure security initiatives are aligned with GHC's business strategy.
- Review security performance and significant security trends.
- Support resolution of cross-functional security conflicts.
- Review significant security incidents and lessons learned.
- Consider security requirements for new technologies and business initiatives.
- Review security resource and investment priorities.
- Escalate significant risks and unresolved issues to executive leadership or the Board.
- Promote accountability and cooperation between business, technology and security functions.

5. Meeting Cadence

The SSC shall meet monthly, with additional meetings called when significant security risks, incidents or urgent decisions require attention. Minutes and key decisions shall be documented and distributed to relevant stakeholders after each meeting.

6. Decision Authority

The SSC has authority to review, evaluate and recommend security policies, priorities and risk treatments within its delegated authority. Where a decision has significant financial, operational, regulatory or strategic implications, the matter shall be escalated to the CEO and/or Board for final approval as appropriate.

Decisions shall be based on:

- Business requirements.
- Security risk.
- Potential business impact.
- Regulatory obligations.
- Technical feasibility.
- Cost and resource implications.
- User and operational impact.

This prevents decisions from being based solely on either security preference or operational convenience.

7. Reporting

The SSC shall provide regular updates to executive leadership and, where appropriate, the Board.

- Reports should include:
- Significant security risks.
- Major security incidents.
- Policy decisions.
- Security performance metrics.
- Risk-treatment progress.
- Security initiatives and resource requirements.
- Issues requiring executive or Board-level decisions.

11. A sample agenda for the first SSC meeting with the password-policy conflict as a key discussion item.

Time	Agenda Item	Lead
5 mins	Welcome and opening	CEO / Chair
10 mins	Introduction to SSC purpose, scope and responsibilities	CISO / Security Governance Lead
10 mins	Review of GHC's current security governance gaps	CISO
15 mins	Password Policy Review and CTO/IT Manager Conflict	CTO & IT Manager
10 mins	Risk and business-impact assessment of proposed password approaches	CISO / Compliance
10 mins	Discussion and decision on preferred approach	SSC
5 mins	Actions, owners and deadlines	Chair
5 mins	Any other business and closing	Chair

12. A 1–2 paragraph briefing note to the CEO explaining how the SSC will resolve cross-functional conflict and maintain strategic alignment.

The Security Steering Committee provides GHC with a formal mechanism for resolving cross-functional security disagreements such as the current password-policy conflict between the CTO and IT Manager. Rather than allowing individual departments to make security decisions independently, the SSC brings together security, technology, compliance, business and executive stakeholders to assess the issue from multiple perspectives. This allows decisions to be based on security risk, business impact, regulatory requirements, operational practicality and resource considerations.

For the password-policy issue, the SSC should evaluate both approaches and select a control strategy that provides appropriate protection without creating unnecessary operational friction. This supports GHC's strategic objectives of improving operational efficiency, maintaining customer trust and fostering innovation. The Committee also creates clear accountability by documenting decisions, assigning owners and escalating significant unresolved risks to executive leadership or the Board. This is consistent with effective information security governance, where security must be aligned with business objectives and supported by appropriate leadership oversight.

6. Governance Maturity Assessment

Required Evidence Task 5

13. A completed maturity assessment for Policy & Documentation, Roles & Responsibilities, Risk Management, Metrics & Reporting, Training & Awareness, and Compliance.

Governance Domain	Current Evidence	Current Level	Reasoning	Target
Policy & Documentation	Policies are inconsistent, inherited from acquisitions and not always current.	2 – Initial	Some policies exist, but they are not consistently maintained or standardised across GHC.	3 – Defined
Roles & Responsibilities	Security ownership and accountability are unclear.	1 – Ad Hoc	There is no sufficiently clear and formal allocation of security responsibilities.	3 – Defined
Risk Management	Organisation is reactive and lacks a formal proactive assessment process.	1 – Ad Hoc	Risk management is primarily driven by problems as they arise rather than a defined process.	3 – Defined
Metrics & Reporting	Technical metrics exist but are not consistently translated into business impact.	2 – Initial	Measurement exists, but reporting is not yet consistently designed for business and Board decision-making.	3 – Defined
Training & Awareness	Annual training is mandatory, but engagement is low.	2 – Initial	A formal training process exists, but its effectiveness and engagement need improvement.	3 – Defined
Compliance	Compliance preparation is audit-driven rather than continuously monitored.	2 – Initial	Compliance activity exists, but it is mainly reactive and focused around audits.	3 – Defined

14. A 12–18 month maturity roadmap containing 3–5 priority initiatives. For each initiative, state the objective, key activities and measurable expected outcome.

Initiative	Timeline	Objective	Key Activities	Measurable Expected Outcome
Governance Structure & Accountability	Months 1–3	Establish clear ownership and decision-making authority for information security.	Formalise the Information Security Charter; establish the SSC; approve RACI; define reporting and escalation paths.	100% of key security governance activities have assigned owners and accountability; SSC operating with

				documented meetings and decisions.
Policy & Documentation Programme	Months 2–6	Create a consistent and current security policy framework across GHC.	Review inherited policies; identify gaps; standardise policies; assign policy owners; establish review and approval process.	All priority security policies documented, approved, communicated and assigned to owners.
Enterprise Risk Management Process	Months 3–9	Move GHC from reactive security management to proactive risk management.	Establish risk methodology; create and maintain security risk register; conduct regular risk assessments; define risk treatment and escalation process.	Formal risk assessment process implemented; key security risks documented with owners, treatments and review dates.
Security Metrics, Training & Awareness	Months 5–12	Improve security performance measurement and employee security awareness.	Define Board-level metrics; establish regular reporting; improve security awareness activities; monitor training participation and effectiveness.	Regular Board/SSC security reporting established; training completion reaches at least 90%; metrics consistently linked to business impact.
Continuous Compliance & Assurance	Months 9–18	Move compliance from an audit-driven approach to continuous monitoring and assurance.	Create compliance obligations register; assign owners; monitor compliance activities; maintain evidence; conduct periodic control reviews.	Compliance obligations have assigned owners and monitoring activities; evidence is maintained continuously rather than only before audits.

15. A 1–2 paragraph executive summary to the Board explaining GHC's current maturity and the strategic importance of the roadmap.

GHC's current governance maturity is assessed at approximately Level 2 – Initial, with Roles & Responsibilities and Risk Management currently showing Level 1 characteristics. While GHC has some security policies, training, metrics and compliance activities, these processes are inconsistent, reactive or insufficiently connected to business decision-making. This maturity level is understandable given GHC's rapid growth, two acquisitions and recent data-leakage near-miss, but it is not sufficient for an organisation whose business depends on customer trust, protection of sensitive health information, regulatory compliance and continued innovation.

The proposed 12–18 month roadmap focuses on establishing governance accountability, standardising policies, introducing proactive risk management, improving metrics and awareness, and establishing continuous compliance and assurance. The objective is to achieve

at least Level 3 – Defined across all six domains, meaning processes are documented, standardised, communicated and supported by clear responsibilities. This will provide GHC with a more consistent and sustainable governance foundation as it expands its market presence, develops new capabilities and integrates future growth. The roadmap also reflects the Week 1 emphasis on executive sponsorship, business alignment, resource allocation, stakeholder engagement, a phased approach and regular review as key factors for successful governance implementation.

Reference:

1. AI
2. IC DFA training materials